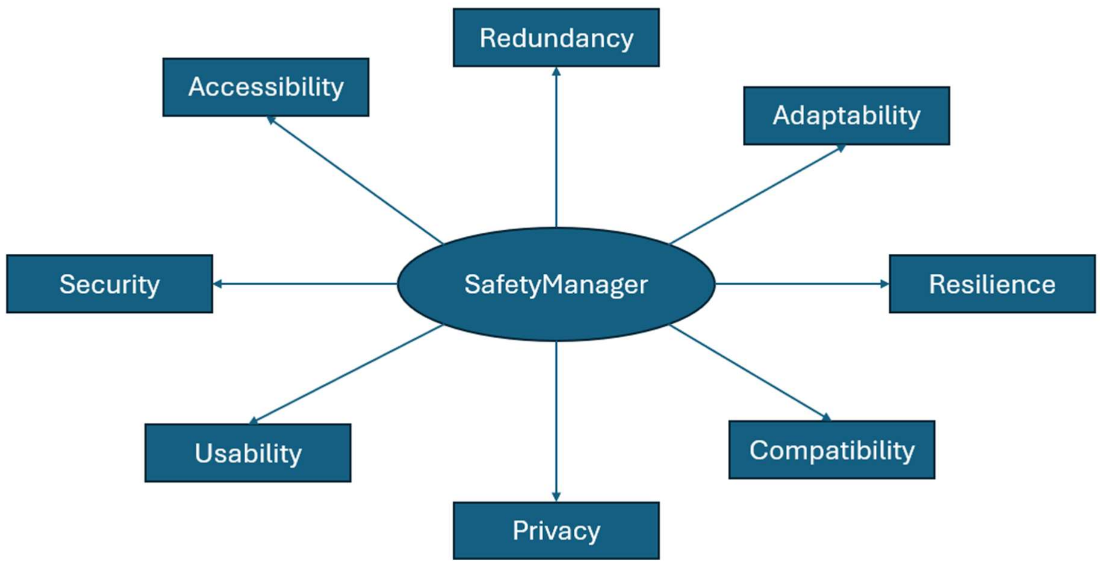
SAFETYMANAGER DESIGN

Contents

Introduction

SafetyManager is a password manager designed with the principles of security, redundancy, usability and privacy. SafetyManager was created to allow users to securely store their passwords while staying private. It also was made to improve on current weaknesses or limitations of current password managers. This design aims to show the features of safetymanager in clear organised sections and a workflow which shows step by step how a user may set their account. It will also provide transparency as there will be a section at the end of this design document of safetymanager's trade-offs.

This design cannot promise a perfectly secure or private password manager as it is impossible to do so. However, this design can promise a more resilient, privacy-first and secure experience for users. For anyone who may try to implement this design, you may require infrastructure, development teams and security teams. Make sure to adapt this design based on your own resources.



The spider diagram shows the main principles which safetymanager is built on. These principles are constantly seen throughout the design of safetymanager. However, this does not include every single principle that safetymanager is built on.

Account and Authentication

- **For signing up, a username is required instead of email.**
- **This means that there will be no email recovery methods can be used to recover accounts**
- **However, this is also a privacy benefit because emails are used to track users extensively across websites.**
- **For the master password, 12 characters minimum are required for the account.**
- **There should also be rate-limiting with progressive lockout to prevent an attacker from brute forcing the password.**
- **On the website, there should be a free password generator on the website you can use for generating the master password.**
- **This free password generator should be able to make strong passwords with a mixture of symbols, letters and numbers but also passphrases.**
- **Users can set up MFA on their account with multiple options**
- **These options include SMS (Not recommended), authentication app (Recommended) hardware key (Max security)**
- **There are 2 types of recovery methods the user can use to recover their account.**
- **The first type of recovery method is a recovery kit**
- **This recovery kit will contain recovery phrases that can be used to reset your password. This will also include a step-by-step guide on how to get through the recovery process.**
- **The second type of recovery method is backup codes**
- **These are about 10 one-time usage backup recovery codes for recovering MFA if you lose your 2FA device.**
- **The user should be warned that if they lose these two recovery methods then the provider cannot help them.**
- **For settings, the user can navigate through security, recovery and subscriptions**
- **For security settings, the user should be able to change their password, perform the password review, configure MFA, check sessions on the account, set session timeouts and delete their account.**
- **For recovery settings, the user should be able to download the recovery kit, view backup recovery codes, configure emergency access, export vault data or import vault data.**
- **For subscriptions, the user should be able to view the features of the free tier and paid tier. They are also able to check their credit card information or switch tiers if needed.**
- **These settings may need to be adapted as the password manager will be an app, web extension and website.**

Data Storage and Encryption

- **For data storage and encryption, the password manager will use end-to-end encryption and a zero-knowledge architecture**
- **This means that not even the provider can see user data inside of the vault.**
- **SafetyManager uses a defence in depth approach to protect user data inside the vault.**
- **The vault will be encrypted using AES-256 with symmetric encryption. AES-256 is currently the strongest encryption algorithm.**
- **The vault's data is saved and stored in two separate ways.**
- **The first way is that the vault's data is stored in cloud storage.**
- **This means that vault is saved via cloud sync to the provider's servers.**
- **This provides redundancy because if your device were to fail then your data would still be saved to the cloud servers.**
- **The second way is that the vault's data is stored locally on the device.**
- **This means that the vault changes are updated saved offline.**
- **This provides further redundancy for if the cloud servers were to fail or you were to lose internet connection then you would still have access to your data.**
- **This local vault should allow users to add entries, delete entries, edit entries, copy passwords/usernames and change settings that don't require cloud sync.**
- **This data should sync back to the cloud once internet connection or cloud server's return.**
- **The vault's data can also be exported and imported**
- **For the export options, the user can use an encrypted JSON export (via master password or a separate file password). They can also use an unencrypted JSON or CSV export.**
- **For the import options, the user can use an encrypted JSON export or a supported format for importing data in the vault.**
- **Import formats should be from other known password managers so users can transfer their data.**
- **When data is imported, the user should be asked if they want it to overwrite current vault data or if they wish to append the imported data to the existing data.**
- **The user will also have self-hosting options.**
- **This will allow the user to self-host their own version of the software if they don't trust the provider to do so.**
- **The self-hosting, if possible, should allow the user to use the software on their own cloud infrastructure or just locally.**
- **The self-hosting options are a paid tier feature.**

Vault Data Organisation and Entry Structures

- **Safetymanager will support data storage for accounts, network credentials, passkeys, identity and credit cards.**
- **For accounts, you can enter the domain of the website(Optional), username/email address of the account (Optional) and the password (Required)**
- **The password can be generated through the password generator and checked for if the password is found in any breaches.**
- **This password generator is user configurable (They can set the number of characters, the number of symbols, numbers or have the generator make passphrases)**
- **You can also underneath the password field enter backup recovery codes for that specific account.**
- **For network credentials, safetymanager would support for SSH, VPN, router/switch and database connection**
- **For SSH, the structure would be protocol, username, password, host (IP address) and port number.**
- **For VPN, the structure would be Protocol, username, password, server, IP address (Optional), pre-shared key.**
- **For Router/switch, it would be provider name, username, password, IP address and Protocol**
- **For database connection, it would be username, password, host and port.**
- **For identity, it would require main details such as Full name, DOB, Email address, Phone number, Physical address, Government ID number and issuing state/country**
- **These identity details should be separated into clear sections like personal details, work details, physical address.**
- **For credit cards, the user should be asked for cardholder name, card number, expiration date, Security code, card type, issuing bank (optional) and billing address (Optional)**
- **Safetymanager will also allow users to organise their passwords using folders.**
- **The users will be able to create folders like account passwords, application passwords or device passcodes.**
- **There will also be nested folder support**
- **This allows users to have sub folders within folders which allows for deeper organization of passwords.**
- **Users should be able to create folders, subfolders within those folders with unlimited depth (based on user storage), move entries between folders (dragging) and search across all folders or specific folders.**

SafetyManager Browser Extension Security

- **The password manager extension will be able to auto-fill usernames and passwords based on domain matching**
- **Domain matching is done by checking the current website's domain against the user's entered domain.**
- **The user's inputted domain should be checked if it's a valid domain**
- **If it is not the correct domain, then the user should be warned but the decision is left in their hands.**
- **The password manager extension also uses Cyrillic character detection**
- **This is done by the checking the domain against a database of Cyrillic characters and patterns.**
- **If Cyrillic characters are detected in the domain, the user is alerted and given the choice to continue**
- **This is because some legitimate websites such as Russian websites uses Cyrillic characters**
- **An example of the alert message could be "Alert: This domain contains Cyrillic characters. Possible homograph attack. Proceed if you know this is a legitimate website"**
- **The extension should then remember if that website is legitimate in a database that uses a verification hash to confirm legit websites.**
- **Users can add to this database with confirmed legitimate websites.**
- **This detection in the future may also use AI-driven detection or behavioural analysis based on known homograph attacks.**
- **The extension should also support a separate password that allows users to reauthenticate before auto-filling the password.**
- **This separate password can be configured so the user can either set it to ask for it every 24 hours or earlier.**
- **The extension should also not show all the passwords like the app or website versions.**
- **The extension will also require the username, master password and MFA (if set) for the first login.**

SafetyManager Compatibility and Free Tier

- **SafetyManager will have website, app and browser extension versions for users to use.**
- **SafetyManager will also be open source for users to audit the code**
- **For the browser extension, this should be supported on Chrome, Firefox, Brave, Microsoft edge and Safari (If possible)**
- **The browser extension must also be mainly local for privacy and should be efficient with RAM usage. Especially on Chrome.**
- **For the website version, SafetyManager will require the username, master password and MFA (if enabled) to authenticate.**
- **The website would be supported on the same browsers as the browser extension.**
- **The website version should also maintain a consistent layout on mobile and desktop devices.**
- **For the app version, SafetyManager should be supported on Windows, Linux, android. If applicable SafetyManager should also support MacOS and IOS.**
- **The app on mobile devices should allow for a separate dedicated app-level passcode or biometrics.**
- **While the app version on desktop should mainly use the master password to reauthenticate or a separate dedicated app-level passcode.**
- **SafetyManager also has a free tier and paid tier.**
- **This is because SafetyManager will have large infrastructure and may be expensive to maintain so a business model is important.**
- **The free tier includes multiple features**
- **For data organisation, it allows users unlimited entries, folders and nested depth.**
- **This is because users deserve to have the ability to organise and have as many passwords entries as possible in a vault they own.**
- **For MFA, the free tier allows MFA options like SMS, authentication app and hardware key.**
- **For hardware key, SafetyManager will support the usage of hardware key.**
- **Users must pay for their own hardware key as it will not be provided for them.**
- **For recovery, users can have a recovery kit, backup recovery codes, backups of vault data and the ability to import vault data from all supported formats.**
- **The free tier will also allow for a password review.**
- **This detection feature will check the strength of passwords, uniqueness and if the passwords are involved in any breaches.**
- **It will provide results only. It will not change anything allowing the user with full control.**
- **The free tier was made generous because it shows the users that security isn't just about budgets or certain tools.**

SafetyManager’s Paid Tier

- **SafetyManager’s paid tier mainly focuses on communication, emergency recovery and business controls.**
- **For emergency recovery, SafetyManager uses a system of emergency access.**
- **Emergency access allows another SafetyManager user to gain access to your account.**
- **Firstly, the main user sets a countdown and defines the secondary user who is allowed access.**
- **This countdown is how long the account is locked for until the user is allowed access.**
- **Once the countdown is finished, the main user is asked if they still have access. If the answer is yes, then the countdown resets.**
- **If there is no response from the main user, an unencrypted copy of the main user’s vault is sent via end-to-end encryption.**
- **This unencrypted copy is automatically made before the 24-hour countdown finishes.**
- **This allows the secondary user to save the passwords in the vault in the case of lockout.**
- **For communication, there is secure vault sharing**
- **This is where users on SafetyManager can send passwords or information over to each other.**
- **This communication would be end-to-end encrypted so that it’s between the users only.**
- **Users can also set a disappearing messaging timer so messages are deleted afterwards to ensure that even if an attacker compromise one of the accounts, then they may not see the information.**
- **There shouldn’t be screenshots of conversations in secure vault sharing happening. SafetyManager if possible, should alert or block screenshots.**
- **For companies, there are a few controls they can use in the paid tier.**
- **Admin users can set password policy, MFA policy, set up logging for access to shared passwords, add or remove users.**
- **Each employee can have their own separate vault within the company.**
- **SafetyManager may also allow for admins to provide an employee list and role list.**
- **These lists would allow SafetyManager to authenticate new employees accounts without admins manually having to do anything.**
- **The employee lists would also have verification hashes and only be accessible to admins to ensure no tampering**
- **After a new employee is authenticated, the admin is alerted.**
- **Custom roles can also be made as admins can define names, permissions and access.**

SafetyManager User Workflow

- **The user first heads to SafetyManager website.**
- **Second, they head to the sign-up page to create a new account**
- **For the sign up, they are first asked for a username**
- **Once they enter a valid username, they are asked to create a master password**
- **They either generate or make one up themselves.**
- **After creating the account, they are asked to download the recovery kit.**
- **Once the user downloads the recovery kit, they are redirected to the interface of their vault.**
- **The user then navigates to the security settings of their account**
- **They enable MFA via authentication app for their account.**
- **After setting up the authentication app, they are given 10 one-time usage backup codes in the case they lose their 2FA device.**
- **The user imports their password vault from the password manager if they used one before.**
- **The password vault is filled with any passwords that the user imported.**
- **The user makes folders such as account passwords, device passwords with sub folders inside of the account passwords called work accounts and personal accounts.**
- **The user then installs the browser extension on their browser chrome.**
- **They authenticate to the extension by entering their username, master password and then typing in the code from the authentication app.**
- **After authentication, they can use the extension to autofill passwords on saved accounts.**
- **The user installs the password manager on their iPhone for easier and quicker access.**
- **They authenticate by entering their username, master password and then typing the code through the authentication app.**
- **A local encrypted copy of the vault is made on their iPhone after authentication**
- **They set up to use face ID to authenticate to the password manager.**
- **After 4 months of using the password manager, the user's device is broken after dropping it.**
- **The user gets the backup recovery codes from cloud storage or another storage media and uses one on the account.**
- **They restore access to their account and set up MFA via authentication app again on a spare device they have.**
- **The user is happy and trusts the password manager, so they pay for a subscription for the paid tier.**
- **The user configures emergency access with 2 months countdown and a family member being the secondary user.**

<u>SafetyManager's Trade-Offs</u>

- **SafetyManager like any other system has trade-offs.**
- **I have identified 6 main trade-offs of SafetyManager**
- **The first trade-off is performance**
- **This trade-off exists because the security features of safetymanager such as end-to-end encryption can be computationally intensive.**
- **This trade-off can be managed by load balancers, management of real-time tools and efficient coding practices.**
- **The second trade-off is compatibility**
- **This trade-off exists because Safetymanager cannot be on every operating system or may have weaker security features on some operating systems compared to others.**
- **This trade-off can be managed through self-hosted software, testing of security features and adapting the password manager to specific browsers or operating systems.**
- **The third trade-off is recovery**
- **This trade-off exists because the provider cannot provide support due to the zero-knowledge architecture where the user has all the keys.**
- **It also exists because there is no email-based recovery which is the easiest method of recovery currently.**
- **This trade-off can be managed through recovery kits, clear warnings, backup recovery codes, backups and emergency access.**
- **The fourth trade-off is accessibility**
- **This trade-off exists because SafetyManager is limited in the accessibility features it can provide.**
- **For example, it cannot provide text-to-speech or any audio features that may compromise the security of the user**
- **This trade-off can be managed through relying on operating system accessibility features and adding accessibility features where possible without compromising security.**
- **The fifth trade-off is business.**
- **This trade-off exists because SafetyManager has a free tier that users can live comfortably on without being blocked by a paywall.**
- **This means that the provider has less money to maintain infrastructure**
- **This trade-off can be managed through the paid tier and using adverts on social media platform to attract people and get ad revenue.**
- **The sixth trade-off is maintainability.**
- **This trade-off exists because SafetyManager has a lot of security features and areas that may require constant updates to keep secure.**
- **This trade-off can be managed through a development team, incremental updates and making the password manager open source.**